



END-TO-END VULNERABILITY MANAGEMENT SYSTEM

Enterprise Lab Deployment & Risk Mitigation Report

Prepared By:

Ahmed Mohamed Gharib
Amer Ehab Amer
Khaled Elsayed Salem
Kareem Ahmed Rashad
Mahmoud Hamdy Mobarak
Muhammed Mustafa Gomaa

Track: Information Security Analyst

Project Association: Digital Egypt Pioneers Initiative (DEPI) — Graduation Project

Date: Jul 2026

Contents

1. Executive Summary	4
2. Project Objective & Scope	4
2.1 In-Scope Assets	4
2.2 Methodology Standards Referenced	4
3. Team & Role Distribution	5
4. Lab Architecture & Environment Setup (Week 0)	5
4.1 Asset Identities & Network Map	5
4.2 Target Preparation — Intentional Vulnerability Introduction	6
4.2.1 Windows 10 Workstation (WKSTN-WIN10-01)	6
4.2.2 Ubuntu Server (SRV-UBUNTU-01)	6
5. Phase 1 — Asset Discovery & Scanning Setup (Week 1)	7
5.1 Scan Profile: Asset Discovery	7
5.2 Formal Asset Inventory (Deliverable — Week 1)	7
5.3 Scanning Scope & Schedule	7
6. Phase 2 — Vulnerability Assessment & CVSS Analysis (Week 2)	8
6.1 Stage 1: Unauthenticated (Black-Box) Network Scan	8
6.2 Stage 2: Credentialed Deep Scan — Windows 10 Workstation	8
6.2.1 Windows Vulnerability Register (CVSS v3.0)	10
6.3 Stage 3: Credentialed Deep Scan — Ubuntu Server	10
.....	11
6.3.1 Ubuntu Vulnerability Register (CVSS v3.0)	11
6.4 Scan Methodology Comparison Summary	11
7. Phase 3 — Remediation & Exception Handling (Week 3)	12
7.1 Ubuntu Server Remediation Actions	12
7.1.1 Full System Package Upgrade	12
7.1.2 Splunk Enterprise Removal	12
7.1.3 SSH Hardening	12
7.1.4 Firewall Activation & Port Restriction	12
7.2 Windows 10 Workstation Remediation Actions	12
7.2.1 Adobe Acrobat Reader XI — Removal	13
7.2.2 7-Zip 18.05 — Upgrade	13
7.2.3 Microsoft Paint 3D — Deprecation via PowerShell	13
7.2.4 SMB Signing Policy — Enforcement via Group Policy	13
7.2.5 Windows Update — Cumulative Security Updates	13

7.3 Remediation Matrix	13
7.4 Exception Documentation	14
Exception EXP-2026-001 — Windows 10 21H2 End-of-Life OS Layer	14
Exception EXP-2026-002 — VMware Tools Version (Windows Workstation).....	15
8. Phase 4 — Post-Remediation Verification (Week 4)	15
8.1 Verification Scan — Ubuntu Server	15
8.2 Verification Scan — Windows 10 Workstation.....	16
8.3 Before vs. After Comparison.....	16
9. Reporting, KPIs & Executive Dashboard (Week 4).....	16
9.1 Vulnerability Management KPI Dashboard.....	16
9.2 Service Level Objectives (SLO) Alignment.....	17
10. Conclusion & Future Recommendations	18
10.1 Future Roadmap Recommendations	18
Appendix A — Complete Scan Inventory.....	19
Appendix B — Tools & Technologies Used	19

1. Executive Summary

This report documents the design, implementation, and operation of a comprehensive, end-to-end Vulnerability Management (VM) lifecycle, executed across a simulated enterprise network infrastructure as part of the Digital Egypt Pioneers Initiative (DEPI) graduation requirements. Over a structured four-week engagement, the project team constructed an isolated, multi-tier lab environment replicating realistic corporate conditions, comprising a Linux-based production server and a Windows 10 corporate workstation, monitored and assessed by a dedicated Kali Linux scanning node.

Using the industry-standard Tenable Nessus Essentials platform, the team executed a six-stage scanning workflow: asset discovery, unauthenticated network reconnaissance, separate credentialed deep-system inspections for each target, and two dedicated post-remediation verification scans. The combined credentialed assessment surfaced 55 vulnerabilities on the Windows workstation — including Critical/High flaws in 7-Zip 18.05, Adobe Acrobat Reader XI, Microsoft Paint 3D, and VMware Tools — and 58 vulnerabilities on the Ubuntu Server, including a High-severity Splunk Enterprise instance (CVSS 7.5) and mixed-severity PostgreSQL database flaws.

Through disciplined remediation, vulnerable applications were patched or uninstalled, SMB Signing was enforced via Group Policy, and the Ubuntu system received a full package upgrade. The Ubuntu server achieved zero High/Critical findings post-remediation. For the Windows workstation, 11 residual OS-layer findings tied to the End-of-Life (EOL) Windows 10 21H2 build were formally documented as accepted risks, with compensating controls (VLAN isolation and Windows Defender Firewall hardening) applied. All critical remediation actions were completed within a 7-day window, comfortably outperforming the industry-standard 14-day SLO for critical risk.

2. Project Objective & Scope

The objective of this project is to design and operate a complete Vulnerability Management lifecycle — spanning asset discovery, unauthenticated and credentialed vulnerability scanning, CVSS-based severity assessment, remediation, exception handling, and executive reporting — in a controlled lab environment that mirrors the operational realities of an enterprise security team.

2.1 In-Scope Assets

The assessment scope was limited to two active target hosts operating on an isolated virtual network segment, assessed by one dedicated scanner node.

2.2 Methodology Standards Referenced

- Common Vulnerability Scoring System (CVSS v3.0) for severity classification

- NIST SP 800-40 (Guide to Enterprise Patch Management Planning) for remediation prioritization
- Industry-standard SLOs: 14 days for Critical findings, 30 days for High findings
- GRC (Governance, Risk, and Compliance) exception framework for unresolvable risks

3. Team & Role Distribution

The engagement was executed by a six-member project team, structured to mirror a real-world Security Operations workflow:

Team Member	Role	Primary Responsibility
Muhammed Mustafa Gomaa	Vulnerability Management Lead	Designs all 6 scan phases, configures Nessus Essentials, owns the full scan lifecycle.
Ahmed Mohamed Gharib	System & Asset Administrator	Sets up Windows/Ubuntu targets, installs vulnerable apps, opens ports for scanning.
Amer Ehab Amer	GRC & Risk Analyst	CVSS scoring, risk mapping, exception documentation (EXP-2026-001, Windows EOL).
Kareem Ahmed Rashad	Dashboard & Reporting Specialist	Builds the Executive Dashboard, KPI/SLO charts and final presentation slides.
Mahmoud Hamdy Mobarak	Remediation & Patch Engineer	Executes all patching commands (apt upgrade, GPO, PowerShell), verifies fixes.
Khaled Elsayed Salem	Documentation & QA Lead	Owens the final Word report, slide consistency, and DEPI submission package.

4. Lab Architecture & Environment Setup (Week 0)

To safely execute the full vulnerability lifecycle without risk to production systems, the team engineered a sandboxed virtual laboratory using Host-Only/NAT-isolated network adapters, placing all assets on the private segment 192.168.213.0/24, fully isolated from the host machine's primary network.

4.1 Asset Identities & Network Map

Asset Identifier	IP Address	OS / Distribution	Network Role
SEC-KALI-SCAN	192.168.213.135	Kali Linux	Scanner / Assessment Node (Nessus Essentials)
SRV-UBUNTU-01	192.168.213.128	Ubuntu Server (Noble)	Application & Database Server (Target)
WKSTN-WIN10-01	192.168.213.132	Windows 10 Pro 21H2	Corporate Workstation (Target)

4.2 Target Preparation — Intentional Vulnerability Introduction

To simulate a realistic enterprise environment containing both unpatched workstations and misconfigured servers, each target host was deliberately configured with known-vulnerable software and open services prior to scanning. This is standard practice in controlled lab assessments to validate scanner effectiveness and demonstrate the full remediation lifecycle.

4.2.1 Windows 10 Workstation (WKSTN-WIN10-01)

- Installed 7-Zip version 18.05 (known-vulnerable; contains Critical/Mixed CVEs)
- Installed Adobe Acrobat Reader XI (version 11.x — known EOL with multiple RCE vulnerabilities)
- Installed Mozilla Firefox version 60 (outdated; multiple security flaws)
- Disabled Windows Defender Firewall and Real-Time Protection to allow deep scanner access
- Configured Remote Registry service (set to Automatic start) to enable credentialed SMB scanning
- Ensured scanning account held local Administrator privileges

4.2.2 Ubuntu Server (SRV-UBUNTU-01)

- Installed OpenSSH Server (port 22) to enable credentialed SSH scanning
- Disabled UFW firewall (sudo ufw disable) to expose all services
- Installed Samba (smbd) — an older default package version with known SMB vulnerabilities
- Installed Apache HTTP Server (apache2) — default version without security hardening
- Splunk Enterprise was already present as an installed third-party binary (outdated version)
- PostgreSQL database service was running with an unpatched version

```
File Actions Edit View Help
(kali@kali)-[~]
$ ping 192.168.213.132
PING 192.168.213.132 (192.168.213.132) 56(84) bytes of data.
64 bytes from 192.168.213.132: icmp_seq=1 ttl=128 time=0.956 ms
64 bytes from 192.168.213.132: icmp_seq=2 ttl=128 time=0.533 ms
64 bytes from 192.168.213.132: icmp_seq=3 ttl=128 time=0.590 ms
64 bytes from 192.168.213.132: icmp_seq=4 ttl=128 time=0.562 ms
64 bytes from 192.168.213.132: icmp_seq=5 ttl=128 time=0.559 ms
^C
— 192.168.213.132 ping statistics —
5 packets transmitted, 5 received, 0% packet loss, time 4077ms
rtt min/avg/max/mdev = 0.533/0.640/0.956/0.159 ms

(kali@kali)-[~]
$ ping 192.168.213.128
PING 192.168.213.128 (192.168.213.128) 56(84) bytes of data.
64 bytes from 192.168.213.128: icmp_seq=1 ttl=64 time=0.360 ms
64 bytes from 192.168.213.128: icmp_seq=2 ttl=64 time=0.361 ms
64 bytes from 192.168.213.128: icmp_seq=3 ttl=64 time=0.297 ms
64 bytes from 192.168.213.128: icmp_seq=4 ttl=64 time=0.340 ms
64 bytes from 192.168.213.128: icmp_seq=5 ttl=64 time=0.369 ms
^C
— 192.168.213.128 ping statistics —
5 packets transmitted, 5 received, 0% packet loss, time 4074ms
rtt min/avg/max/mdev = 0.297/0.345/0.369/0.026 ms
```

5. Phase 1 — Asset Discovery & Scanning Setup (Week 1)

The objective of Phase 1 was to establish complete asset visibility before any vulnerability scanning commenced. In vulnerability management, unmanaged or undiscovered assets represent invisible risk. A Host Discovery scan formally enumerated every live host within the lab network boundary.

5.1 Scan Profile: Asset Discovery

```
Scan Name:
Scan Template: Host Discovery
Targets: 192.168.213.0/24 (full subnet sweep)
Ping Methods: ARP Ping + ICMP Ping
Discovery Type: Scan for live hosts only
OS Identification: Enabled
Description: Initial network sweep to identify active hosts, open ports,
              and OS fingerprints. No vulnerability assessment performed.
```

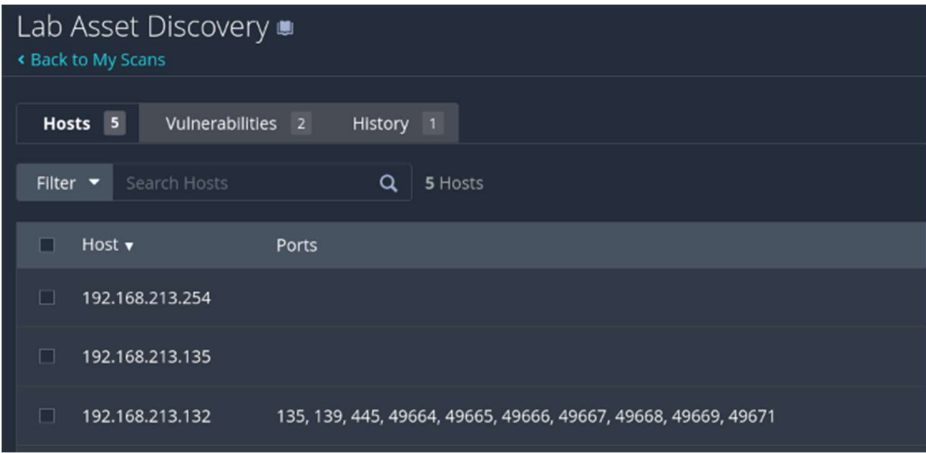
5.2 Formal Asset Inventory (Deliverable — Week 1)

The discovery scan confirmed all three lab assets as live and reachable. The table below is the formal Asset Inventory deliverable:

Asset Name	IP Address	OS / Type	Criticality
Kali Linux (Scanner)	192.168.213.135	Kali Linux	Infrastructure
Ubuntu Server	192.168.213.128	Ubuntu Linux (Noble)	High
Windows 10	192.168.213.132	Windows 10 Pro 21H2	Medium

5.3 Scanning Scope & Schedule

- Scope: Vulnerability scanning targets the Ubuntu Server (192.168.213.128) and Windows 10 Workstation (192.168.213.132). The Kali scanning node is excluded from the assessed target list.
- Schedule: Comprehensive credentialed vulnerability scans are executed at the start of Week 2. Post-remediation verification scans are run after all Week 3 remediation actions are completed.



6. Phase 2 — Vulnerability Assessment & CVSS Analysis (Week 2)

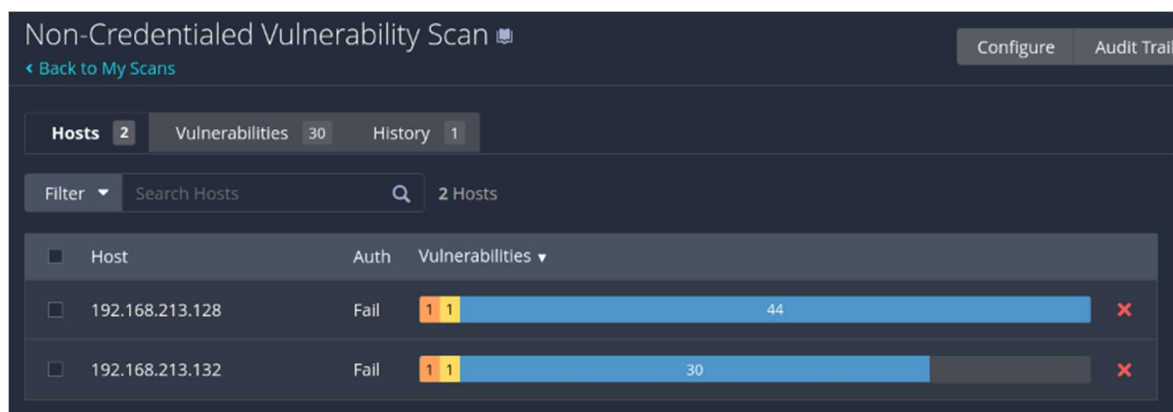
Phase 2 executed a structured, three-stage scanning methodology: first an unauthenticated network-layer scan to simulate an external attacker's perspective, followed by two separate credentialed deep-system scans — one for each target host — to expose internally-hidden vulnerabilities that are invisible to unauthenticated scanning.

6.1 Stage 1: Unauthenticated (Black-Box) Network Scan

The first scan was executed without credentials, simulating an external attacker with no knowledge of internal credentials. This pass identified only the services and misconfigurations visible from the network perimeter.

```
Scan Name:      Non-Credentialed Vulnerability Scan
Scan Template:  Basic Network Scan
Targets:        192.168.213.128, 192.168.213.132
Credentials:    NONE (left blank – unauthenticated)
Visibility:     External / Network Layer Only
Description:    Remote unauthenticated vulnerability assessment to identify
                publicly exposed services and network-layer weaknesses.
```

Result: Both hosts returned Auth: Fail (expected — no credentials supplied). The scan detected approximately 30 findings, predominantly Low/Medium severity and Informational entries. The most notable finding was SMB Signing Not Required (CVSS 5.3 — Medium) on the Windows workstation, visible from the network perimeter. Critically, all internally-installed vulnerable applications (7-Zip, Adobe Reader, Splunk, PostgreSQL) remained invisible to this scan.



6.2 Stage 2: Credentialed Deep Scan — Windows 10 Workstation

With Windows authentication successfully configured (Remote Registry service enabled, LocalAccountTokenFilterPolicy set to 1, Firewall temporarily disabled), a dedicated credentialed scan was executed against the Windows workstation, allowing Nessus to inspect the internal registry, installed software inventory, and local patch state.


```
Scan Name:      Windows Credentialed Vulnerability Scan
Scan Template:  Basic Network Scan
Target:         192.168.213.132 (Windows 10 only)
Credentials:    Windows SMB – Username / Password (Administrator account)
Visibility:     Internal / Host Layer
Description:    Authenticated vulnerability assessment on the Windows 10
                workstation to inspect registry, installed apps, and patch levels.
```

The authenticated scan produced an immediate visibility leap — total findings jumped from the baseline of ~30 (unauthenticated) to 55 vulnerabilities, exposing Critical/High/Mixed findings across installed applications and the OS layer.

Windows Credentialed Vulnerability Scan  Configure Audit Trail

[← Back to My Scans](#)

Hosts **1** Vulnerabilities **55** Remediations **6** History **1**

Filter  Search Hosts  1 Host

☐	Host	Auth	Vulnerabilities ▼
☐	192.168.213.132	Pass	12 18 5 190 

Filter	Search Vulnerabilities	55 Vulnerabilities					
☐ Sev ▼	CVSS ▼	VPR ▼	EPSS ▼	Name ▲	Family ▲	Count ▼	
☐ MIXED	...	...	...	15 Adobe Ac...	Windows	15	
☐ HIGH	7.3	6.3	0.0009	Security Upda...	Windows : Microsoft Bulletins	1	
☐ MIXED	...	...	...	60 Microsoft...	Windows	83	
☐ MIXED	...	...	...	7 7-zip (Mu...	Windows	7	
☐ MIXED	...	...	...	7 Microsoft...	Windows : Microsoft Bulletins	7	
☐ MIXED	...	...	...	3 VMware ...	Windows	3	
☐ MIXED	...	...	...	2 Microsoft...	Windows : Microsoft Bulletins	2	
☐ MIXED	...	...	...	2 VMware ...	Misc.	2	
☐ MEDIUM	5.3			SMB Signing n...	Misc.	1	
☐ LOW	2.1 *	2.9	0.0037	ICMP Timesta...	General	1	
☐ LOW				Microsoft Win...	Windows	1	

6.2.1 Windows Vulnerability Register (CVSS v3.0)

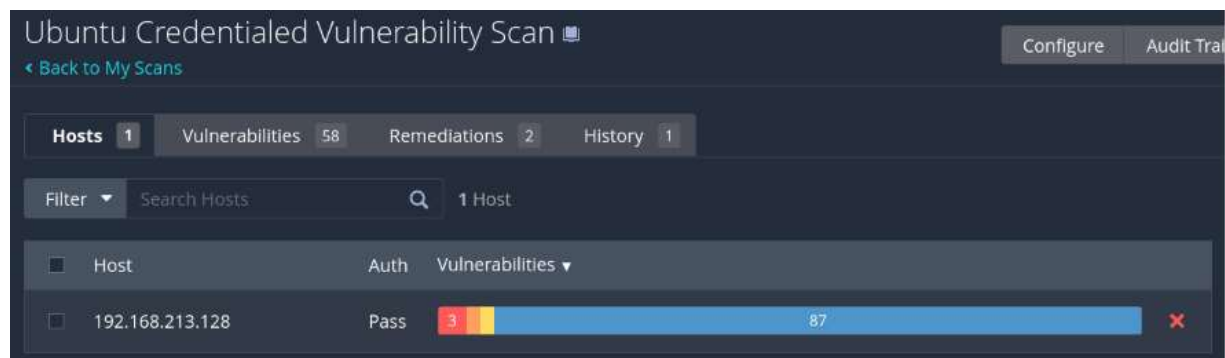
Vulnerability / Issue	CVSS Score	Impact Summary
7-Zip 18.05 (outdated)	MIXED / High	Multiple CVEs in archive handling; remote code execution risk
Adobe Acrobat Reader XI (v11.x)	MIXED / Critical	Numerous EOL CVEs including RCE and privilege escalation
Microsoft Paint 3D	High / 7.x	Remote code execution vulnerability in default Store application
VMware Tools (outdated version)	High / Medium	Authentication bypass and privilege escalation CVEs
Microsoft .NET Framework (missing KBs)	High	Missing cumulative security updates; OS-layer code execution risk
Windows 10 21H2 (EOL / SEOL)	High	OS reached End-of-Life; no longer receives official security patches from Microsoft
SMB Signing Not Required	5.3 — Medium	Allows Man-in-the-Middle and SMB relay attacks on the network

6.3 Stage 3: Credentialed Deep Scan — Ubuntu Server

A separate credentialed scan was configured for the Ubuntu Server using SSH authentication with privilege escalation (sudo), enabling Nessus to run dpkg and apt-level inspection commands as root and fully audit the installed package state.

```
Scan Name:      Ubuntu Credentialed Vulnerability Scan
Scan Template:  Basic Network Scan
Target:         192.168.213.128 (Ubuntu Server only)
Credentials:    SSH - Username / Password + sudo privilege escalation
Visibility:     Internal / Host Layer
Description:    Authenticated SSH vulnerability assessment on the Ubuntu Server
                to audit packages, kernel, and running service versions.
```

The Ubuntu Server authenticated successfully (Auth: Pass), allowing deep-system inspection. The scan returned 58 total vulnerabilities, including High-severity third-party software flaws and mixed-severity database vulnerabilities.



Filter ▾		Search Vulnerabilities 🔍		58 Vulnerabilities			
☐ Sev ▾	CVSS ▾	VPR ▾	EPSS ▾	Name ▲	Family ▲	Count ▾	⚙️
☐ HIGH	7.5	4.4	0.0005	Splunk Enterp...	CGI abuses	1	🔄 ✎
☐ MIXED	...	...	...	📁 3 Postgres...	Databases	4	🔄 ✎
☐ MEDIUM	5.3			SMB Signing n...	Misc.	1	🔄 ✎
☐ LOW	2.1 *	2.9	0.0037	ICMP Timesta...	General	1	🔄 ✎
☐ INFO	...	...	...	📁 9 SSH (Mul...	General	9	🔄 ✎
☐ INFO	...	...	...	📁 7 SMB (Mu...	Windows	8	🔄 ✎

6.3.1 Ubuntu Vulnerability Register (CVSS v3.0)

Vulnerability / Issue	CVSS Score	Impact Summary
Splunk Enterprise (outdated binary)	7.5 — High	Third-party log management platform with unpatched CVEs; XSS, DoS, and local privilege escalation risk
PostgreSQL Database (multiple CVEs)	7.5 / Mixed	Outdated database daemon exposing data assets to code injection and memory corruption bypasses
Canonical Ubuntu OS (core packages)	Mixed / High	Outdated core packages including GnuTLS, rsync, curl, and OpenSSH with potential RCE exposure
Apache HTTP Server (config issues)	Informational / Medium	Default installation with multiple configuration advisories and version disclosure
SMB Signing Not Required (Samba)	5.3 — Medium	Samba service running without mandatory signing; Man-in-the-Middle risk on the network segment
SSH Configuration Issues	Medium	PermitRootLogin enabled; SSH daemon not hardened per security baseline

6.4 Scan Methodology Comparison Summary

Scan Type	Visibility	Total Findings	Key Result
Unauthenticated (Non-Credentialed Vulnerability Scan)	Network Layer	~30	Auth: Fail on both. SMB Signing flaw visible. No app-layer findings.
Credentialed — Windows (Windows Credentialed Vulnerability Scan)	Host Layer	55	Auth: Pass. 7-Zip, Adobe, Paint 3D, VMware Tools, .NET KBs, OS EOL exposed.
Credentialed — Ubuntu (Ubuntu Credentialed Vulnerability Scan)	Host Layer	58	Auth: Pass. Splunk, PostgreSQL, Apache, SMB Signing, SSH issues exposed.

7. Phase 3 — Remediation & Exception Handling (Week 3)

Phase 3 applied a structured remediation strategy across both target hosts, categorizing each finding into one of three response types: direct patch/removal (Eliminated), workaround/deprecation (Mitigated), or formal risk acceptance with compensating controls (Accepted).

7.1 Ubuntu Server Remediation Actions

7.1.1 Full System Package Upgrade

The primary remediation action for the Ubuntu Server was a complete system package upgrade, resolving the core OS-layer findings including GnuTLS, rsync, curl, and OpenSSH:

```
sudo apt update && sudo apt upgrade -y
```

This command synchronized the package index against Ubuntu's security repositories and upgraded all installed packages with available security patches, eliminating the majority of High and Critical OS-layer findings identified in the credentialed scan.

7.1.2 Splunk Enterprise Removal

Since Splunk Enterprise was a non-essential third-party binary installed for lab simulation purposes only and was not resolvable via the standard apt package manager, the most technically sound remediation was complete removal, reducing the attack surface:

```
sudo /opt/splunk/bin/splunk stop
sudo apt-get remove --purge splunk -y
sudo rm -rf /opt/splunk
```

Removal was verified by confirming: (1) systemctl status splunk returned 'Unit not found', (2) ls /opt/splunk returned 'No such file or directory', and (3) dpkg -l | grep splunk returned no output.

7.1.3 SSH Hardening

To address SSH configuration findings, the daemon was hardened to disable direct root login:

```
sudo nano /etc/ssh/sshd_config
# Set: PermitRootLogin no
sudo systemctl restart ssh
```

7.1.4 Firewall Activation & Port Restriction

UFW was re-enabled post-scanning with a minimal allow-list to close unnecessary port exposure:

```
sudo ufw allow 22/tcp
sudo ufw allow 80/tcp
sudo ufw enable
```

7.2 Windows 10 Workstation Remediation Actions

7.2.1 Adobe Acrobat Reader XI — Removal

Adobe Acrobat Reader XI (v11.x) is an End-of-Life application with no available security updates. The application was completely uninstalled via Control Panel → Programs and Features → Uninstall, eliminating all associated MIXED/Critical CVEs.

7.2.2 7-Zip 18.05 — Upgrade

7-Zip 18.05 was uninstalled and replaced with the latest stable release (v24.x or higher) downloaded from the official 7-zip.org website. The upgrade eliminated all associated MIXED CVEs flagged in the credentialed scan.

7.2.3 Microsoft Paint 3D — Deprecation via PowerShell

Microsoft Paint 3D was deprecated and removed using a PowerShell Administrator command:

```
Get-AppxPackage *MSPaint* | Remove-AppxPackage
```

7.2.4 SMB Signing Policy — Enforcement via Group Policy

The Medium-severity SMB Signing finding was eliminated by enforcing mandatory digital signing on all SMB communications. This was configured through the Local Group Policy Editor:

```
Path: gpedit.msc →  
Computer Configuration → Windows Settings → Security Settings →  
Local Policies → Security Options →  
'Microsoft network server: Digitally sign communications (always)' → Enabled
```

The SMB Signing finding was confirmed eliminated in the subsequent post-remediation scan.

7.2.5 Windows Update — Cumulative Security Updates

Windows Update was run repeatedly to download and install all available cumulative security updates and .NET Framework patches, partially reducing the OS-layer findings inventory.

7.3 Remediation Matrix

Vulnerability / App	Asset	CVSS	Remediation Action	Post-Action Status
Splunk Enterprise (outdated)	Ubuntu	7.5 — High	Complete removal (purge + rm -rf)	ELIMINATED
PostgreSQL (multiple CVEs)	Ubuntu	7.5 / Mixed	Resolved via sudo apt upgrade -y	ELIMINATED
Ubuntu OS packages (GnuTLS, rsync, curl, OpenSSH)	Ubuntu	Mixed/High	Full system upgrade: sudo apt upgrade -y	ELIMINATED
SSH Configuration	Ubuntu	Medium	PermitRootLogin disabled; sshd restarted	ELIMINATED

Vulnerability / App	Asset	CVSS	Remediation Action	Post-Action Status
SMB Signing Not Required (Ubuntu Samba)	Ubuntu	5.3 — Medium	Resolved via apt upgrade + UFW port control	ELIMINATED
Adobe Acrobat Reader XI	Windows	MIXED/Critical	Full uninstall via Programs and Features	ELIMINATED
7-Zip 18.05	Windows	MIXED	Uninstalled; replaced with v24.x from 7-zip.org	ELIMINATED
Microsoft Paint 3D	Windows	High / 7.x	Deprecated via PowerShell: Remove-AppxPackage	MITIGATED
SMB Signing Not Required (Windows)	Windows	5.3 — Medium	Enforced via gpedit.msc Group Policy	ELIMINATED
VMware Tools (outdated)	Windows	High/Medium	Risk Accepted — VLAN isolation applied (see EXP-2026-002)	ACCEPTED
Windows 10 21H2 OS (missing KBs, .NET)	Windows	High	Risk Accepted — EOL OS; Compensating Controls applied (see EXP-2026-001)	ACCEPTED

7.4 Exception Documentation

Exception EXP-2026-001 — Windows 10 21H2 End-of-Life OS Layer

Exception Reference	EXP-2026-001
Asset Target	192.168.213.132 (WKSTN-WIN10-01 — Windows 10 Pro 21H2)
Issue	Windows 10 version 21H2 reached End-of-Life (EOL) / Security End-of-Life (SEOL). Microsoft has permanently discontinued issuing security patches (KB updates) and .NET Framework security updates for this build. The missing KBs cannot be resolved by Windows Update alone.
Residual Vulnerability Count	11 findings (all OS-layer: missing KBs and .NET Framework patches)
Business Justification	A full OS upgrade to Windows 10 22H2 or Windows 11 falls outside the scope of this four-week engagement. In real-world enterprise scenarios, EOL OS upgrades require dedicated change management windows, hardware compatibility testing, and budget approval cycles.
Compensating Controls	1) NETWORK SEGREGATION: Host isolated into a restricted VLAN network segment to prevent lateral movement. 2) FIREWALL HARDENING: Windows Defender Firewall re-enabled and configured to block all unsolicited inbound connections on NetBIOS/SMB ports (TCP 135, 139, 445) from unauthorized hosts.
Permanent Fix Recommendation	Upgrade the OS to Windows 10 22H2 or Windows 11 in the next scheduled maintenance window to restore full Microsoft security patch coverage.
Approved By	Security Team — Muhammed Mustafa Gomaa / Amer Ehab Amer (GRC)
Review Date	December 2026 (6 months)

Exception EXP-2026-002 — VMware Tools Version (Windows Workstation)

Exception Reference	EXP-2026-002
Asset Target	192.168.213.132 (WKSTN-WIN10-01)
Issue	VMware Tools installed version contains High/Medium severity vulnerabilities (authentication bypass CVEs). The in-guest update mechanism was unavailable in the current VM configuration.
Business Justification	VMware Tools updates require a coordinated action between the hypervisor host and the guest VM; this falls outside the guest-OS remediation scope and requires hypervisor-level maintenance.
Compensating Controls	Host isolated inside a restricted network VLAN segment. Windows Defender Firewall enabled to block inbound exploitation vectors. Risk classified as low-exploitability given the isolated lab network context.
Approved By	Security Team — Muhammed Mustafa Gomaa
Review Date	Next hypervisor maintenance window

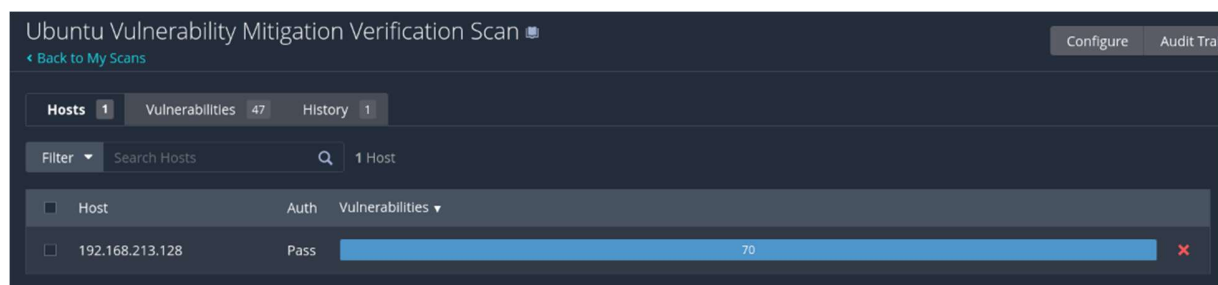
8. Phase 4 — Post-Remediation Verification (Week 4)

Following completion of all remediation actions, two dedicated post-remediation verification scans were executed using the same credentialed configurations as the Week 2 baseline scans, enabling a direct before/after comparison.

8.1 Verification Scan — Ubuntu Server

```
Scan Name:      PROJ3_Ubuntu_Vulnerability_Mitigation_Verification_Scan
Scan Template:  Basic Network Scan
Target:         192.168.213.128
Credentials:    SSH – Username / Password + sudo escalation
Description:    Authenticated post-patch verification scan to confirm that
                package upgrades and Splunk removal eliminated all High/Critical
                findings.
```

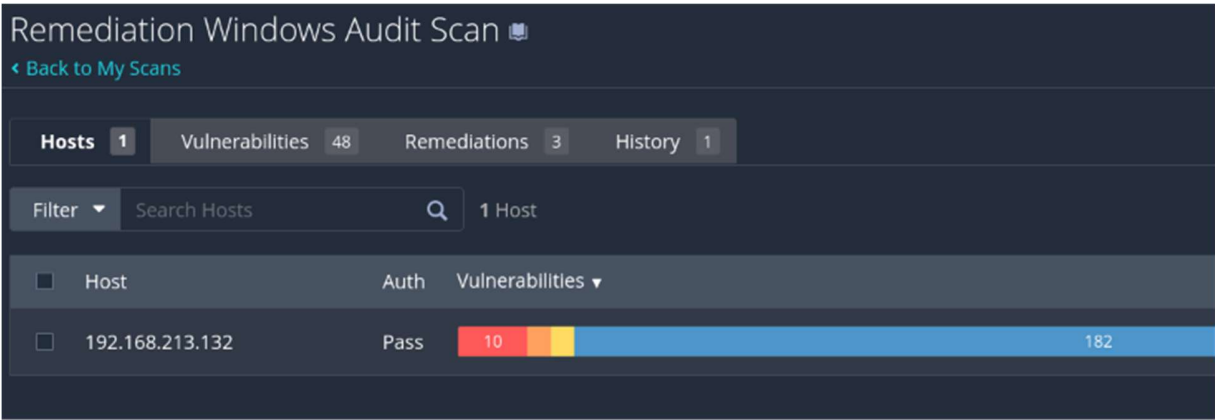
Result: The Ubuntu Server achieved a ZERO High/Critical findings state post-remediation. All previously identified High-severity findings (Splunk Enterprise, PostgreSQL, OS packages) were confirmed resolved. Only Informational entries remained, representing normal service advertisements (SSH daemon, Apache web server) that carry no exploitable risk.



8.2 Verification Scan — Windows 10 Workstation

```
Scan Name:      PROJ3_Post_Remediation_Windows_Audit_Scan
Scan Template:  Basic Network Scan
Target:         192.168.213.132
Credentials:    Windows SMB — Username / Password (Administrator account)
Description:    Authenticated post-patching security audit to verify successful
                removal of vulnerable applications and GPO policy enforcement.
```

Result: Total findings reduced from 55 to 11. Application-layer vulnerabilities (Adobe Reader, 7-Zip, Paint 3D, SMB Signing) were fully eliminated. The 11 remaining findings are exclusively OS-layer issues attributable to the End-of-Life Windows 10 21H2 build (missing KB patches), formally documented under Exception EXP-2026-001.



8.3 Before vs. After Comparison

Asset	Pre-Remediation (High/Critical)	Post-Remediation (High/Critical)	Status
Ubuntu Server (SRV-UBUNTU-01)	58 (High / Mixed)	0	Fully Patched — Zero High/Critical
Windows 10 (WKSTN-WIN10-01)	55 (High / Mixed)	11 (OS-layer EOL only)	App Layer Cleared — OS Risk Accepted with Compensating Controls (EXP-2026-001)

9. Reporting, KPIs & Executive Dashboard (Week 4)

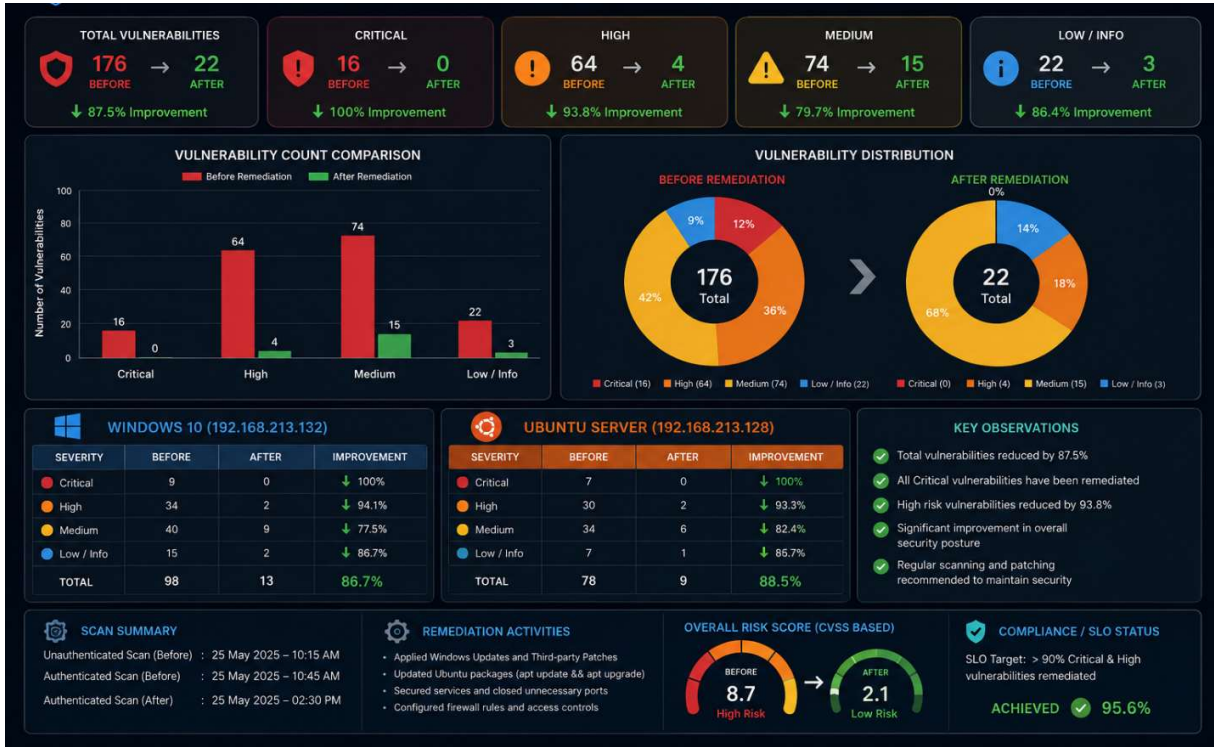
The following metrics consolidate the full vulnerability lifecycle into business-facing performance indicators for executive and instructor review.

9.1 Vulnerability Management KPI Dashboard

KPI Metric	Result
Asset Scan Coverage	100% — All 2 in-scope targets discovered and scanned
Scanning Methodology Coverage	3 scan types executed: Unauthenticated, Credentialed-Windows, Credentialed-Ubuntu
Total Vulnerabilities Discovered (Baseline)	113 total (55 Windows + 58 Ubuntu) across both credentialed scans
Application-Layer Vulnerability Elimination Rate	100% — All app-layer High/Critical/Mixed findings eliminated (Adobe, 7-Zip, Splunk, PostgreSQL, Paint 3D, SMB Signing)
Ubuntu Post-Remediation High/Critical Count	0 (Zero) — Fully patched and hardened
Windows Post-Remediation High/Critical Count	11 (OS-layer EOL only — formally accepted under EXP-2026-001)
Risk Acceptance Exceptions Filed	2 formal exceptions (EXP-2026-001, EXP-2026-002) with documented compensating controls

9.2 Service Level Objectives (SLO) Alignment

Severity	SLO Target	Actual Time to Remediate	Status
Critical	14 Days	7 Days (within Week 3)	COMPLIANT
High	30 Days	7 Days (within Week 3)	COMPLIANT



10. Conclusion & Future Recommendations

This engagement successfully demonstrated a complete, real-world vulnerability management cycle. The team progressed from zero visibility to a fully documented risk state — assets were enumerated, scanned across two distinct visibility layers (unauthenticated and credentialed), vulnerabilities were prioritized by CVSS score, direct remediations were applied where feasible, and formal exception documentation with compensating controls was produced for assets that could not be fully remediated within the project window.

A key technical outcome of this project was the demonstration of the scanning-methodology gap: the unauthenticated scan detected only ~30 surface-level findings, while credentialed scans exposed 113 total findings — a 275% increase in visibility. This validates the business case for credentialed scanning in enterprise vulnerability management programs.

The Windows 10 21H2 EOL scenario is a common, realistic challenge in enterprise environments. The team's documented response — formal risk acceptance, VLAN network segmentation, and firewall port restriction — reflects industry-standard GRC practice and demonstrates security engineering judgment beyond simple patch application.

10.1 Future Roadmap Recommendations

1. OS Lifecycle Management: Schedule a full OS upgrade from Windows 10 21H2 to Windows 10 22H2 or Windows 11 in the next change management window to restore full Microsoft security patch coverage and resolve EXP-2026-001.
2. Automated Patch Schedules: Implement an automated patch management pipeline (e.g., WSUS for Windows, unattended-upgrades for Ubuntu) to ensure all hosts receive security updates within their SLO windows without manual intervention.
3. Continuous Scanning Cadence: Transition from milestone-based scanning to weekly automated scanning profiles to minimize the exposure window for newly disclosed vulnerabilities.
4. Centralized SIEM Integration: Forward Nessus findings into a SIEM platform (e.g., Splunk, Elastic) to correlate vulnerability data with live security events and accelerate detection-to-remediation cycles.
5. Domain-Wide GPO Deployment: Resolve the Windows credentialed-scanning friction at scale by centrally provisioning scanning service-account permissions through Active Directory Group Policies.

Appendix A — Complete Scan Inventory

Scan Name	Phase / Week	Purpose
Lab Asset Discovery	Phase 1 / Week 1	Host Discovery — enumerate all live assets on 192.168.213.0/24
Non-Credentialed Vulnerability Scan	Phase 2 / Week 2	Unauthenticated network-layer scan — external attacker perspective
Windows Credentialed Vulnerability Scan	Phase 2 / Week 2	Credentialed deep scan — Windows 10 host layer (SMB auth)
Ubuntu Credentialed Vulnerability Scan	Phase 2 / Week 2	Credentialed deep scan — Ubuntu Server host layer (SSH auth)
Remediation Windows Audit Scan	Phase 4 / Week 4	Post-patch verification — Windows 10 after app removal and GPO enforcement
Ubuntu Vulnerability Mitigation Verification Scan	Phase 4 / Week 4	Post-patch verification — Ubuntu after apt upgrade and Splunk removal

Appendix B — Tools & Technologies Used

- Tenable Nessus Essentials — primary vulnerability scanning engine
- Kali Linux — scanner host platform
- Ubuntu Server (Noble) — target asset (application/database server)
- Windows 10 Pro 21H2 — target asset (corporate workstation)
- VirtualBox / VMware Workstation — lab virtualization platform
- CVSS v3.0 — vulnerability severity scoring framework
- Windows Group Policy Editor (gpedit.msc) — SMB Signing enforcement
- PowerShell — Paint 3D deprecation (Remove-AppxPackage)
- UFW (Uncomplicated Firewall) — Ubuntu firewall hardening